

Agentic AI Security Scoping Matrix

<https://aws.amazon.com/ko/blogs/security/the-agentic-ai-security-scoping-matrix-a-framework-for-securing-autonomous-ai-systems/>

Agentic AI Security Scoping Matrix

→ **Agency / autonomy / action authority boundary**

→ “Agent에게 무엇을 할 권한을 주며, 어느 정도까지 human approval 없이 행동하게 한 것인가?”



AWS의 calendar 예제도 보면 차이가 굉장히 명확해. **Scope 1**은 일정 조회·추천까지만 하고, **Scope 2**는 초대장을 만들 수 있지만 사람이 승인해야 전송하며, **Scope 3**은 사람이 “회의 잡아줘”라고 시작하면 agent가 스스로 판단해서 실제 calendar에 등록한다. **Scope 4**에서는 사람이 아예 “회의 잡아줘”라고 요청하지 않아도 meeting notes 같은 environment change를 감지하여 agent가 필요성을 판단하고 자체적으로 일정은 생성한다.

Agency는 agent가 operating environment에서 무엇을 할 수 있도록 허용받았는가—접근 가능한 system, operation, resource modification 같은 capability / permission의 범위이고,

Autonomy는 그 허용된 범위 안에서 human intervention 없이 얼마나 독립적으로 판단하고 실행할 수 있는가를 의미한다.

Scope 1 = Read-only

Scope 2 = Approval-gated

Scope 3 = Human-initiated autonomous execution

Scope 4 = Self-initiated autonomous execution

Scope	AWS 명칭	Agency	Autonomy / Human oversight	동작 특성	AWS가 강조하는 주요 security focus
Scope 1	No Agency	None — read-only operation, fixed workflow path	None — human initiated, predefined execution steps	Agent가 정보를 조회·분석·추천할 수 있지만 external system이나 data를 변경하지 않음. Fixed workflow와 read-only operation 중심	Workflow integrity, prompt injection 방지, execution 간 isolation, input/state validation, audit
Scope 2	Prescribed Agency	Limited — system을 변경할 capability와 여타 tool access 가능	Limited — consequential action은 mandatory HITL approval 필요	Agent가 action을 준비·추천할 수 있고 environment를 변경할 capability도 있지만, 실제 consequential action은 human approval 후 실행	Approval workflow 보호, authorization bypass 방지, approver identity verification, approval record, secure human-agent channel
Scope 3	Supervised Agency	High — 여러 system 변경 및 dynamic tool selection 가능	High — human이 시작하지만 이후 autonomous execution, human guidance는 optional	Human이 goal/task를 시작하면 agent가 planning, dynamic tool selection, multi-step execution을 독립적으로 수행하고 environment를 변경 가능	Runtime action monitoring, agency boundary, scope creep (Agent가 처음 부여받은 task-permission-resource 범위를 실행 중에 스스로 넓혀버리는 것) 방지, identity propagation (원래 사용자의 identity/context를 agent harness를 통해 tool 및 external system까지 전달해서, 각 system이 “이 요청이 누구를 대신한 것인지”를 알고 그 사용자의 권한 범위 안에서만 처리하게 만드는 것), behavioral anomaly detection, kill switch / intervention, original intent와의 alignment
Scope 4	Full Agency	Full — comprehensive system access, multi-system orchestration, self-adaptive operation	Full — self-initiated action, continuous autonomous operation; human은 strategic supervisory oversight	Human의 직접 trigger 없이 environment event나 condition을 감지해 agent가 스스로 workflow를 시작하고 지속적으로 autonomous operation 수행	Continuous behavioral validation, agency boundary enforcement, capability drift 방지, anomaly detection, automated containment, tamper-resistant human override / fail-safe

Scope 4

Agent proposes action

→ Policy / Agency Boundary Check

→ ALLOW / DENY / REQUIRE APPROVAL

→ Runtime enforcement

그리고 문제가 생기면:

Anomaly / Policy violation

→ Automated containment

→ 필요 시 Human override

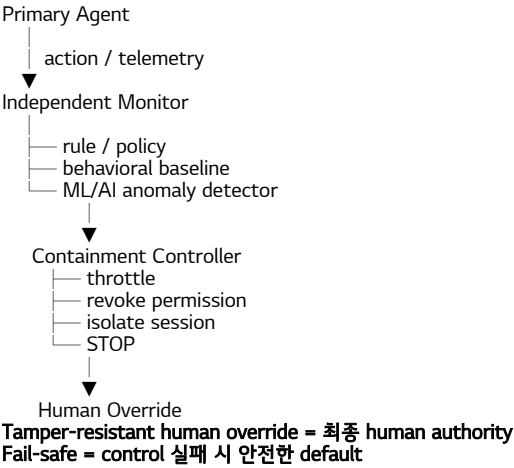
→ control 자체가 실패하면 Fail-safe

도 연결돼.

네가 연구하고 있는 Action Permission 관점에서는 특히 이렇게 대응돼:

Agency boundary enforcement = 평상시 action permission control

Automated containment = 독립적인 monitoring/control mechanism에 의한 automated containment



용어	의미	예시
Agency boundary enforcement	Agent가 허용된 tool·resource·action·permission 범위 밖으로 나가지 못하도록 runtime에서 강제하는 것	Agent가 read_calendar만 허용됐는데 send_email을 호출하려 하면 policy layer에서 DENY
Automated containment	이상 행동이나 policy violation이 감지되면 사람의 개입을 기다리지 않고 자동으로 agent의 영향 범위를 축소·격리·중단하는 것	비정상 tool call 반복 → session 중단, tool access revoke, credential disable, agent isolation
Tamper-resistant human override	사람이 agent를 강제로 중지·제한할 수 있는 통제 수단은 두되, 그 수단은 agent가 수정·우회·비환성화할 수 없게 만드는 것	관리자 kill switch는 agent runtime 밖의 control plane에 두고 agent가 해당 policy/API를 수정하지 못하게 함
Fail-safe	control failure나 분화실한 상태가 발생하면 위험한 action을 계속하는 대신 안전한 상태로 전환하는 것	authorization service 응답 없음 → action 실행이 아니다 DENY / STOP / REQUIRE APPROVAL